

Cyber Security Gap Assessment

Scenario 3: Indian Railways — IRCTC Online Reservation Platform

Organization: Indian Railways Digital Services (IRCTC) | Industry: Public Transportation

Exercise 1: Security Gap Assessment

IIIT-B Cybersecurity Cohort 58

August 2026

Scenario Summary

Indian Railways Digital Services operates the IRCTC online reservation ecosystem used by millions of passengers daily. Recent incidents involving fake bookings, credential theft, and automated booking bots have raised concerns. Before the upcoming festive booking season, the Ministry of Railways has commissioned this cybersecurity gap assessment of the reservation platform.

Technology stack: IRCTC Website, Android & iOS apps, Passenger Reservation System, Oracle Database, Kubernetes, Redis, Load Balancers, API Gateway, Payment Gateway, Aadhaar Verification, SMS Gateway, Active Directory, Office 365, GitHub Enterprise, SIEM. Organization size: 900 IT employees (120 Developers, 40 DevOps Engineers, 15 Security Engineers, 60 Customer Support, plus third-party vendors). Third-party dependencies: Payment Banks, Aadhaar Services, SMS Gateway, third-party booking-platform vendors.

Primary threat scenario: credential stuffing, booking bots, API attacks, insider misuse, and service disruption affecting ticket reservations.

Real-World Context (Research Findings)

The following publicly reported incidents were reviewed to ground this assessment in IRCTC's actual threat history and to validate that the scenario's "known concerns" reflect real, ongoing risk:

- **Booking-bot / Tatkal abuse:** In June 2025, Indian Railways deactivated approximately 2.5 crore (25 million) suspected fake user accounts after uncovering large-scale abuse of the Tatkal booking system by illicit third-party software that bypassed CAPTCHA and OTP checks using proxy servers. Aadhaar-based OTP authentication was subsequently made mandatory for Tatkal bookings from July 2025.
- **Insider-enabled ticketing fraud:** A CBI official and a former IRCTC employee were previously arrested for developing and distributing illicit auto-booking software to travel agents — evidence that both insider knowledge and vendor/ex-employee access are realistic attack paths for this platform.
- **Historical large-scale data exposure:** Reports in 2016 and again in 2018 alleged breaches affecting roughly 10 million user records; a 2022 report described data of approximately 30 million railway users appearing on dark-web forums, underscoring the standing risk to the passenger database and its backups.
- **Application-layer weaknesses:** Independent security researchers reported flaws in IRCTC's password-reset flow (CAPTCHA reuse enabling unlimited OTP requests, 2024) and in the IRCTC insurance portal (nominee details modifiable without OTP or a security question, reported to CERT-In in July 2024 and fixed within a week) — both consistent with the scenario's "some APIs lack proper authentication" concern.

These findings were used to calibrate the Likelihood ratings in Section 6 (e.g. bot-driven Tatkal abuse and legacy/API weaknesses are rated ALMOST CERTAIN / LIKELY because they are corroborated by real, recent incidents, not merely hypothetical).

Rating Scales Used in This Assessment

No scale legend was pre-printed in the exercise template, so the standard ISO 31000-aligned scales taught in this course were applied consistently across all sections:

- Sensitivity: Public → Internal → Confidential → Restricted
- Criticality: Low → Medium → High → Critical
- Likelihood: Rare → Unlikely → Possible → Likely → Almost Certain
- Impact: Negligible → Minor → Moderate → Major → Severe
- Risk Treatment Strategy: Avoid (eliminate the risk) / Mitigate (reduce likelihood or impact) / Transfer (shift the risk, e.g. insurance) / Accept (consciously tolerate a low-impact risk)

Crown Jewel Selection Criteria (used in Task 2)

- C1 — Stores or processes highly sensitive PII, financial, or national-ID data
- C2 — Required for a core business function; compromise stops primary operations
- C3 — High regulatory or legal exposure if compromised
- C4 — Directly named as an active, known weakness in the scenario clues
- C5 — Single point of failure that enables broad or lateral compromise

Task 1 — Asset Identification & Classification

From the scenario, 13 unique assets were identified and classified by Sensitivity and Criticality.

Task 2 — Crown Jewels

The five assets below meet the most crown-jewel criteria and represent the highest-value targets on the platform.

Task 3 — Vulnerability Identification

Ten vulnerabilities were identified directly from the scenario's "Known Concerns."

Task 4 — Attack Scenarios

For each vulnerability, the attack an adversary could realistically carry out is mapped below.

Task 5 — Prevention, Detection & Mitigation Controls

Specific controls are recommended for each attack, organized by Prevention, Detection, and Mitigation.

Task 6 — Likelihood, Impact & Risk Statements

Each vulnerability-attack pair is rated for Likelihood and Impact (see scales above) and expressed as a formal Risk Statement.

Task 7 — Risk Treatment

Each risk is assigned a Risk Treatment Strategy, a justification, and specific actions to implement it.

Sources

- IRCTC deactivates ~2.5 crore fake accounts; Aadhaar OTP mandated for Tatkal from July 2025 — [newsonair.gov.in](https://www.newsonair.gov.in)
- “System Rigged for Agents?” — Tatkal booking bot complaints — Republic World
- IRCTC Tatkal ticket scam and illicit auto-booking software — hacker9.com
- CBI official / ex-IRCTC employee held for Tatkal ticket scam — Tribune India, Deccan Herald
- IRCTC insurance portal data-exposure vulnerability, 2024 — CERTpro
- IRCTC website/password-reset flaw allowing account and booking manipulation — GBHackers
- Data of ~30 million railway users compromised, found on dark web (2022) — Business Standard

| Asset Name | Category | Sensitivity | Criticality | Justification

1 | Passenger Reservation System (PRS) | Software / Application | Restricted | Critical | Core engine processing all bookings, cancellations, and seat allocation nationwide; any downtime halts ticket sales countrywide, especially damaging during Tatkal/festive periods.

2 | Oracle Database (Passenger & PNR Records) | Software / Data | Restricted | Critical | Central store of PNR records and passenger PII (name, ID, contact, travel history, Aadhaar linkage) for millions of users; breach exposes mass PII and violates data-protection obligations.

3 | IRCTC Website | Software / Application | Confidential | Critical | Primary public booking channel carrying the highest transaction volume; outages or bot abuse during Tatkal cause nationwide public and political fallout.

4 | Android & iOS Mobile Apps | Software / Application | Confidential | High | Second major booking channel used by the majority of retail passengers; compromise or unavailability directly hits ticket sales and customer trust.

5 | API Gateway | Software / Infrastructure | Restricted | Critical | Single control point for website, app, and third-party vendor traffic; scenario confirms some APIs lack proper authentication, making it a high-value target.

6 | Payment Gateway Integration | Software / Financial | Restricted | Critical | Processes all online payments via partner banks; compromise enables large-scale financial fraud and breaks regulatory payment-security expectations.

7 | Aadhaar Verification Service | Software / Data | Restricted | Critical | Integrates with national Aadhaar e-KYC for identity verification; leakage or misuse of Aadhaar data carries severe legal penalties and reputational damage.

8 | Active Directory & Privileged Accounts | Software / Identity Infrastructure | Restricted | Critical | Central identity store for ~900 IT staff, developers and vendors; scenario confirms privileged passwords are never rotated, making full-network compromise easy.

9 | Passenger Database Backups | Data | Restricted | Critical | Full copies of passenger PII/PNR data; scenario confirms backups sit on shared servers with weaker isolation than production, creating an easy exfiltration path.

10 | Legacy Booking / Ticketing Applications | Software | Confidential | High | Older applications running on unsupported software per scenario; absence of vendor patches leaves known, unremediated vulnerabilities exploitable by attackers.

11 | GitHub Enterprise (Source Code Repository) | Software / Intellectual Property | Restricted | High | Houses proprietary source code for booking/payment systems and potentially embedded configuration or secrets; compromise enables supply-chain or targeted exploit development.

12 | Third-Party Vendor Access to Production | Process / Access | Restricted | Critical | Scenario confirms vendors directly maintain production systems; broad, unmonitored vendor access is a direct path for supply-chain compromise or insider misuse.

13 | Customer Support Portal (Booking History Access) | Software / Application | Restricted | High | Support staff can view full passenger booking history; broad access without need-to-know controls creates insider misuse and data-leakage risk.

| Crown Jewel Asset | Criteria Met (list #s) | Primary Threat | Business Impact if Compromised

1 | Oracle Database (Passenger & PNR Records) | C1, C2, C3, C4, C5 | Data breach / mass exfiltration of PII and PNR records | Leak of millions of passenger records; Digital Personal Data Protection Act penalties; identity-theft/fraud against citizens; severe reputational damage to the Ministry of Railways.

2 | Passenger Reservation System (PRS) | C2, C4, C5 | Bot-driven overload / denial of service leading to booking outage | Total booking outage nationwide during peak (Tatkal) demand; direct revenue loss; public and political backlash against Indian Railways.

3 | API Gateway | C2, C4, C5 | API abuse, authentication bypass, automation/bot attacks | Unauthorized bookings, bulk data scraping and fraud; cascading outage across every channel (web, app, vendors) that depends on the gateway.

4 | Payment Gateway Integration | C1, C2, C3, C4 | Payment fraud / interception of financial data | Direct monetary loss to passengers and IRCTC; regulatory/RBI scrutiny; loss of consumer trust in online rail payments.

5 | Active Directory & Privileged Accounts | C2, C4, C5 | Credential compromise, privilege escalation, lateral movement, ransomware | Full domain compromise cascading into PRS, database and payment systems; potential ransomware encryption of production servers immediately before the festive booking season.

| Vulnerability Description | Type | Affected Asset(s) | Evidence from Scenario

1 | Booking bots bypass CAPTCHA protections | Technical | IRCTC Website, Mobile Apps, API Gateway | Scenario: "Booking bots bypass CAPTCHA protections."

2 | Some APIs lack proper authentication | Technical | API Gateway, Payment Gateway | Scenario: "Some APIs lack proper authentication."

3 | Legacy applications run on unsupported software | Technical | Legacy Booking / Ticketing Applications | Scenario: "Legacy applications still run on unsupported software."

4 | Third-party vendors have direct, standing access to maintain production systems | Third-Party / Process | PRS, Production Servers | Scenario: "Third-party vendors maintain production systems."

5 | Passenger database backups are stored on shared servers | Technical / Process | Passenger Database Backups | Scenario: "Passenger database backups are stored on shared servers."

6 | Customer support has broad, unrestricted access to passenger booking history | People + Process | Customer Support Portal, Oracle Database | Scenario: "Customer support can access passenger booking history."

7 | Privileged account passwords have not been rotated | Technical / Process | Active Directory & Privileged Accounts | Scenario: "Privileged passwords have not been rotated."

8 | Production servers expose unnecessary network services | Technical | Production Servers, PRS | Scenario: "Production servers expose unnecessary services."

9 | Vulnerability assessments across the environment are overdue | Process | All IT assets (organization-wide) | Scenario: "Vulnerability assessments are overdue."

10 | Reservation system lacks adequate capacity / anti-automation controls for Tatkal surge traffic | Technical / Availability | PRS, IRCTC Website, API Gateway | Scenario: "Tatkal booking traffic overwhelms systems daily."

| Vulnerability | Possible Attack | Attack Type | Likely Attacker | Attack Goal

1 | Bots bypass CAPTCHA | Automated scripts register thousands of fake accounts and instantly grab Tatkal tickets, denying access to genuine passengers | Bot Attack / Business Logic Abuse | Organized ticket touts / rogue travel agents (external) | Illicitly acquire scarce Tatkal tickets in bulk and resell them for profit

2 | APIs lack authentication | Attacker calls unauthenticated endpoints directly to book tickets, pull PNR/passenger data, or manipulate fares, bypassing the website entirely | API Attack (Broken Authentication / BOLA) | External hacker | Data theft and fraudulent, unauthorized bookings

3 | Legacy unsupported software | Attacker exploits known, unpatched CVEs in end-of-life components to achieve remote code execution | Application Attack (known-vulnerability exploitation) | External hacker / ransomware group | Gain a foothold, escalate access, potentially deploy ransomware

4 | Vendor production access | Compromised vendor credentials, or a malicious vendor insider, push unauthorized code/changes directly into production | Supply Chain Attack | Third-party vendor (compromised or malicious) | Plant a backdoor, disrupt operations, or exfiltrate data

5 | Backups on shared servers | Attacker who first compromises any co-located workload on the shared server pivots to and exfiltrates the full backup dataset | Data Exfiltration / Lateral Movement | External hacker (via a lower-value shared system) | Bulk theft of PII/PNR data for sale on the dark web

6 | Customer support broad access | A support agent, or their phished/compromised account, browses or exports booking history of citizens for personal gain, stalking, or resale | Insider Threat / Account Abuse | Insider (current employee) or external attacker via a compromised support account | Unauthorized surveillance, data resale, harassment, or fraud

7 | Privileged passwords not rotated | Attacker authenticates using an old leaked, phished, or ex-employee privileged credential that was never changed | Credential-Based Attack / Privilege Escalation | Former employee/contractor, or external hacker with leaked credentials | Full domain / administrative compromise

8 | Unnecessary exposed services | Attacker scans exposed ports/services (e.g. stale admin panels, unused protocols) and exploits a weak or default configuration | Network / Infrastructure Attack | External hacker (opportunistic scanning) | Gain initial access to the production network

9 | Overdue vulnerability assessments | Known but undiscovered vulnerabilities remain exploitable for extended periods, giving attackers a wide, undetected window (often chained with #3, #8) | Systemic Risk (enabler across attack types) | Any (external hacker, ransomware group) | Sustain long, undetected dwell time within any successful breach

10 | Tatkal surge overwhelms systems | Attacker times a volumetric or application-layer flood to coincide with Tatkal opening, turning normal congestion into a full outage, or threatens to repeat it for extortion | Denial of Service | Competing touts wanting exclusive access, or a hacktivist/extortionist | Deny service to genuine passengers, extort IRCTC, or damage Railways' reputation

| Attack | Prevention — How to STOP it | Detection — How to KNOW it's happening | Mitigation — How to REDUCE DAMAGE

1 | Bot-driven Tatkal ticket scalping | Advanced bot mitigation (behavioural analytics, device fingerprinting, invisible challenge); enforce Aadhaar-linked OTP for Tatkal; one active session per user; rate-limit booking attempts per account/IP | Real-time booking-velocity analytics per IP/device; SIEM alerts on abnormal multi-account patterns from the same fingerprint/proxy range; anomaly detection on tickets-issued-per-second | Auto-block/blacklist flagged accounts and IP ranges; cancel confirmed bot-booked tickets within policy; continue periodic mass deactivation of fraudulent accounts

2 | Unauthenticated API abuse | Enforce OAuth2/JWT authentication and authorization on every endpoint; require API keys/mTLS at the gateway; mandatory API security testing before release | API gateway logging with anomaly detection on unauthenticated/failed-auth spikes; SIEM correlation of unusual API traffic | Immediately revoke/rotate exposed API keys; emergency WAF/gateway rule to block the offending endpoint; patch and retest before re-exposing

3 | Legacy software exploitation | Inventory all legacy applications; prioritize migration/upgrade; apply compensating controls (segmentation, virtual patching/WAF) where upgrade is not immediate | Vulnerability scans tuned to flag EOL software; IDS/EDR signatures for known exploit attempts against legacy CVEs | Isolate legacy systems in a segmented zone; maintain tested rollback/restore plans; accelerate decommission timeline

4 | Vendor supply-chain compromise | Least-privilege, time-bound, approval-based vendor access via PAM/jump-host; mandatory code review and change approval for vendor changes; contractual security SLAs | Session recording/monitoring of all vendor privileged sessions; SIEM alerts on vendor activity outside approved change windows | Immediately revoke vendor access on suspicious activity; roll back unauthorized changes from version control; conduct a vendor security audit

5 | Backup exfiltration | Move backups to isolated, access-controlled, encrypted storage separate from shared/multi-tenant servers; encrypt at rest (AES-256) with separately managed keys | File integrity monitoring on backup storage; alerts on unusual access, copy, or download of backup files | Immediately isolate and re-secure backup storage; rotate credentials of anyone with access; forensic review; notify passengers/regulator if exfiltration is confirmed

6 | Insider misuse of booking history | Role-based access control with least privilege; mask PII fields (partial ID/phone) by default; require supervisor approval for full-record access | User and Entity Behaviour Analytics (UEBA) on support-staff query patterns; audit logging of every record view/export | Suspend the offending account immediately; revoke unnecessary access; notify affected individuals per policy

7 | Privileged credential compromise | Privileged Access Management (PAM) enforcing mandatory rotation; short-lived, vaulted credentials; phishing-resistant MFA for all privileged/admin accounts | PAM/SIEM alerts on privileged logins from unusual locations/devices or off-hours; alerts when credential age exceeds policy | Force immediate rotation of all privileged credentials; review privileged activity logs for misuse; revoke and reissue via the PAM vault

8 | Exploitation of exposed services | CIS-benchmark hardening of production builds; disable/remove unused services and ports; firewall/segmentation limiting exposure to required services only | Recurring external/internal port and service scanning; SIEM/IDS alerts on connections to unexpected exposed services | Immediately disable the exposed service; patch/harden the host; review for signs of compromise via that service

9 | Prolonged undetected exposure | Recurring vulnerability-management program (monthly scans, quarterly pen tests) with SLA-bound remediation, prioritized ahead of the festive season | Vulnerability-management dashboard tracking scan coverage/cadence; flags on any asset overdue for assessment | Commission an emergency assessment across production immediately; fast-track remediation of critical/high findings

10 | Tatkal-time denial of service | Elastic auto-scaling of the PRS/API layer for known peak windows; cloud-based DDoS protection/CDN scrubbing in front of website and APIs; queue-based virtual waiting room for Tatkal | Real-time traffic/infrastructure monitoring with alerts on abnormal request volume or latency spikes at Tatkal opening; SIEM correlation with known bot IP ranges | Activate DDoS scrubbing/failover capacity; throttle/queue excess traffic while preserving service for verified genuine users; post-incident capacity review

| Vulnerability + Attack | Likelihood | Impact | Risk Statement

1 | Bots bypass CAPTCHA → Tatkal ticket scalping | ALMOST CERTAIN | MAJOR | There is an almost certain risk that organized touts/bots will continue to bypass CAPTCHA and Tatkal controls to mass-book tickets, resulting in major public-trust erosion, political scrutiny of the Ministry of Railways, and denial of service to genuine passengers during peak festive travel.

2 | Unauthenticated APIs → unauthorized data/booking access | LIKELY | SEVERE | There is a likely risk that an external attacker will exploit unauthenticated API endpoints to access passenger data or make fraudulent bookings, resulting in severe data-privacy violations, financial fraud, and regulatory action.

3 | Legacy software → exploitation / compromise | LIKELY | SEVERE | There is a likely risk that an attacker will exploit unpatched vulnerabilities in unsupported legacy applications to gain unauthorized system access, resulting in severe operational disruption and potential ransomware deployment across production systems.

4 | Vendor production access → supply-chain attack | POSSIBLE | SEVERE | There is a possible risk that a compromised or malicious third-party vendor will introduce unauthorized changes into production systems, resulting in severe, widespread compromise of the reservation platform and its dependent systems.

5 | Backups on shared servers → bulk data exfiltration | LIKELY | SEVERE | There is a likely risk that an attacker who compromises any co-located workload on the shared servers will pivot to and exfiltrate the passenger database backups, resulting in severe, large-scale exposure of PII for millions of passengers.

6 | Customer support broad access → insider misuse | POSSIBLE | MODERATE | There is a possible risk that a support employee, or an attacker who compromises a support account, will misuse broad access to view or leak passenger booking history, resulting in moderate reputational damage and privacy violations for affected individuals.

7 | Privileged passwords not rotated → credential compromise | LIKELY | SEVERE | There is a likely risk that an attacker will authenticate using a stale, previously leaked, or ex-employee privileged credential that was never rotated, resulting in severe, wide-reaching compromise of Active Directory and all dependent production systems.

8 | Unnecessary exposed services → network intrusion | POSSIBLE | MAJOR | There is a possible risk that an attacker will discover and exploit an unnecessarily exposed service on production servers to gain initial access, resulting in major disruption to reservation services and further internal compromise.

9 | Overdue vulnerability assessments → extended undetected exposure | ALMOST CERTAIN | MAJOR | There is an almost certain risk that known and unknown vulnerabilities across the IRCTC environment remain unidentified and unremediated due to overdue assessments, resulting in a major, prolonged window of exploitability ahead of the high-traffic festive booking season.

10 | Tatkal capacity gap → denial of service | ALMOST CERTAIN | MAJOR | There is an almost certain risk that Tatkal-time traffic surges, worsened by bot activity, will overwhelm the reservation system, resulting in major service outages, lost ticket revenue, and significant public dissatisfaction during peak travel periods.

| Risk | Strategy | Justification | Specific Actions

1 | Bots bypass CAPTCHA → Tatkal scalping | Mitigate | Tatkal service cannot be discontinued and ongoing tout abuse cannot be accepted; effective technical/process controls exist and are already partly in motion (Aadhaar OTP mandate) | (1) Complete rollout of Aadhaar-linked OTP for all Tatkal bookings. (2) Deploy behavioural bot detection and device fingerprinting. (3) Enforce per-account/IP rate limiting and a virtual waiting room. (4) Continue automated detection and mass deactivation of fraudulent accounts.

2 | Unauthenticated APIs → data/booking fraud | Mitigate | APIs are essential to core operations; the risk is addressed through standard secure-engineering practice, not by avoidance | (1) Mandate OAuth2/JWT authentication on all endpoints. (2) Run API security testing/pen tests before every release. (3) Deploy API gateway WAF policies. (4) Continuous API discovery to catch shadow/undocumented endpoints.

3 | Legacy software → exploitation | Mitigate (phased Avoid via decommission) | Immediate replacement of every legacy system is not feasible; risk must be reduced with compensating controls while migration is planned | (1) Inventory and risk-rank all legacy applications. (2) Apply network segmentation and virtual patching (WAF/IPS). (3) Fast-track a migration/decommission roadmap. (4) Increase monitoring on legacy hosts.

4 | Vendor production access → supply-chain attack | Mitigate | Third-party vendors are operationally necessary; the risk is reduced through access governance rather than eliminated | (1) Implement PAM with just-in-time, approval-gated vendor access. (2) Mandatory code review/change approval for vendor changes. (3) Session recording and monitoring for all vendor privileged access. (4) Contractual security SLAs and periodic vendor audits.

5 | Backups on shared servers → data exfiltration | Mitigate | Backups are required for business continuity; the risk is reduced by isolating and encrypting them, not by eliminating backups | (1) Migrate backups to a dedicated, access-controlled, encrypted storage tier. (2) Encrypt backups at rest with separately managed keys. (3) Enable file integrity monitoring and access alerting. (4) Restrict backup access to named backup administrators only.

6 | Customer support broad access → insider misuse | Mitigate | The support function needs some data access to serve passengers; risk is reduced through least privilege and monitoring, not eliminated | (1) Implement RBAC with field-level PII masking by default. (2) Require supervisor approval and justification logging for full-record access. (3) Deploy UEBA to flag anomalous bulk record access. (4) Periodic access recertification.

7 | Privileged passwords not rotated → credential compromise | Mitigate | Regulatory and security best practice; low relative cost against the scale of potential breach impact | (1) Deploy a PAM solution enforcing automatic credential rotation. (2) Enforce phishing-resistant MFA (FIDO2) for all privileged accounts. (3) Force an immediate one-time rotation of all existing privileged credentials. (4) Continuously monitor privileged-account usage.

8 | Unnecessary exposed services → network intrusion | Mitigate | Standard hardening measure; low cost relative to the risk reduction achieved | (1) CIS-benchmark hardening of all production servers. (2) Disable/remove unused services and close unneeded ports. (3) Enforce network segmentation/firewall rules limiting exposure. (4) Recurring external attack-surface scanning.

9 | Overdue vulnerability assessments → undetected exposure | Mitigate | A core risk-management control that is addressable through process and resourcing; cannot be avoided given the platform's scale and regulatory profile | (1) Commission an emergency vulnerability assessment/pen test immediately, ahead of the festive season. (2) Establish a recurring (monthly scan/quarterly pen test) VM program with SLA-bound remediation. (3) Assign dedicated ownership and executive reporting for overdue findings. (4) Track remediation via a centralized vulnerability-management dashboard.

10 | Tatkai capacity gap → denial of service | Mitigate | Service availability cannot be avoided given genuine Tatkai demand; risk is reduced through architecture and DDoS-protection investment | (1) Deploy cloud-based DDoS protection/CDN scrubbing in front of the website and APIs. (2) Implement auto-scaling and a virtual waiting-room queue for peak windows. (3) Load-test infrastructure ahead of the festive season. (4) Establish an incident-response runbook specific to Tatkai-time outages.